

1. Objetivo del Pentest

- Identificar la vulnerabilidad de control de acceso que permite a un usuario ver información de otra cuenta.
- Evaluar el impacto real que esta falla representa para la confidencialidad de los datos de los clientes.
- Proporcionar recomendaciones de mitigación claras para que el equipo de desarrollo solucione el problema.

2. Alcance

- **Dentro del alcance:** Aplicación web principal de Aurora Market (módulos de registro, autenticación, perfil de usuario, carrito de compras e historial de pedidos).
- **Fuera del alcance:** Redes sociales de la empresa, correos personales o corporativos de los empleados, infraestructura de proveedores externos y ataques físicos.

3. Permisos y Condiciones

- **Permisos requeridos:** Autorización escrita y firmada por la dirección de Aurora Market junto a un acuerdo de confidencialidad (NDA).
- **Condiciones acordadas:**
 - Realizar las pruebas en horarios de menor tráfico comercial para no afectar la disponibilidad.
 - Prohibido ejecutar ataques de denegación de servicio (DoS/DDoS) o alterar datos reales de los usuarios.

4. Tipo de Pentest

- **Tipo elegido:** Gray-Box (Caja Gris).
- **Justificación:** Se cuenta con información parcial de la aplicación (existencia de base de datos y sistema de autenticación, pero sin código fuente), lo que permite simular el comportamiento de un usuario autenticado o un atacante con acceso básico.

5. Planificación

- **Objetivos:** Identificar la vulnerabilidad de control de acceso (IDOR), evaluar el impacto real en la confidencialidad de los datos de los clientes y proveer recomendaciones de mitigación para el equipo de desarrollo.
- **Alcance:** Evaluación centrada exclusivamente en la aplicación web principal de Aurora Market (módulos de registro, autenticación, perfil, carrito e historial), excluyendo redes sociales, correos, infraestructura de terceros y ataques físicos.
- **Permisos y condiciones:** Contar con autorización escrita (autorización formal y NDA) por parte de la dirección, ejecutando las pruebas en horarios de menor tráfico y prohibiendo rotundamente ataques DoS o alteración de datos reales.
- **Metodología a utilizar:** OWASP Web Security Testing Guide (WSTG) como marco de referencia para evaluar los controles de seguridad web.
- **Recopilación de información previa:** Análisis manual de la estructura de la web, formularios, cookies e identificadores manipulables en las URLs basándose en la información parcial provista por la empresa.
- **Recursos necesarios:** Cuentas de prueba configuradas (roles A y B) y herramientas técnicas de análisis web (Burp Suite o inspector del navegador).
- **Programación del pentest:** Coordinación de la ejecución de las pruebas en ventanas horarias nocturnas o de baja carga comercial para minimizar cualquier impacto en la plataforma.

6. Fases del Pentest

- **Reconocimiento:** Mapeo general de las secciones y funcionalidades de la tienda web.
- **Análisis de Vulnerabilidades:** Búsqueda de fallas en el control de acceso e identificación de parámetros manipulables (ej. IDs en URLs).
- **Explotación:** Confirmación de la vulnerabilidad intentando acceder a los datos de la cuenta de prueba B estando autenticado como el usuario A.
- **Post-explotación:** Determinación del nivel de acceso alcanzado (ver historial, modificar datos, etc.) sin vulnerar usuarios reales.
- **Informe:** Documentación técnica de los hallazgos y redacción de la guía de remediación para los desarrolladores.

7. Investigación

- **Metodología elegida:** OWASP WSTG.
- **Justificación:** Es el estándar técnico referente para aplicaciones web y provee casos de prueba específicos para validar la gestión de identidades y controles de acceso (*Broken Access Control* / IDOR), lo cual atiende directamente el problema reportado por el cliente.